

Security+ 3.2 · Firewall Types

Mestre CyberSec · Lesson 3.2 — Firewall Types (8:00) · [Assistir Vídeo no YouTube](#) ↗ · Treino Interativo: edusouzamarques.github.io/cybersec

Executive Lesson Summary: Evolução: ACL stateless; stateful (lembra a conexão); NGFW (aplicação+user+threat intel+SSL inspection); UTM (NGFW+IPS+AV anti-spam num appliance); WAF (protege o HTTP/S do site: SQLi/XSS/CSRF).

💡 Key Exam Highlights & Critical Concepts

- Stateful lembra a conexão; stateless é por pacote
- NGFW = stateful + aplicação + usuário + threat intelligence
- WAF (L7) protege o web app; NGFW protege o tráfego da rede

🎯 Exam Tips & Typical CompTIA Scenarios

- 'application-aware firewall'=NGFW
- 'inspects HTTP for SQL injection'=WAF

Why is this advanced coverage required for SY0-701? Video lectures provide foundational concepts, but CompTIA tests practical engineering judgment and requires deep familiarity with the following protocols, acronyms, and operational nuances in this domain:

• Access Control List (ACL)

A sequential list of permit/deny rules applied on routers or stateless firewalls to filter traffic by source/destination IP address and port. Rules are processed top-down and the first match wins.

⚠ **Exam Trap:** ACL = mecanismo típico do firewall STATELESS. Não rastreia conexões: o tráfego de retorno precisa de regra explícita. Lembre-se: 'first match wins'.

• Stateless Firewall (Packet Filter)

A firewall that filters each packet individually against ACL rules, with no memory of previous packets or connection state. It cannot determine whether traffic belongs to an established session.

⚠ **Exam Trap:** Gatilhos de prova: 'per-packet', 'no connection awareness', 'uses ACLs' = stateless. Distinção-chave: stateless avalia o pacote isolado; stateful avalia a conexão inteira.

• Stateful Firewall

A firewall that maintains a state table of active connections, tracking each session end-to-end and automatically allowing return traffic for established flows.

⚠ **Exam Trap:** 'Remembers the connection' / 'tracks sessions' = stateful. ARMADILHA: stateful puro NÃO é application-aware nem inspeciona conteúdo — isso é NGFW.

• Next-Generation Firewall (NGFW)

An application-aware firewall that combines stateful filtering with application identification and control, user identity awareness, threat intelligence feeds, and SSL/TLS decryption inspection.

⚠ **Exam Trap:** 'Application-aware firewall' = NGFW. Se a questão cita 'user + application + threat intelligence' ou 'decrypts SSL/TLS', é NGFW — NÃO escolha WAF, que protege apenas o web app.

• Unified Threat Management (UTM)

An all-in-one security appliance that bundles a firewall with IPS, antivirus, anti-spam and other security services in a single device (effectively NGFW plus multiple integrated protections).

⚠ **Exam Trap:** 'All-in-one security appliance' com firewall + IPS + AV + anti-spam = UTM. Distinção para a prova: UTM enfatiza os serviços empilhados num appliance; NGFW enfatiza aplicação/usuário/threat intel.

• Web Application Firewall (WAF)

A Layer 7 firewall placed in front of a web application that inspects HTTP/HTTPS traffic to block web attacks such as SQL injection, cross-site scripting (XSS) and CSRF.

⚠ **Exam Trap:** 'Inspects HTTP for SQL injection' = WAF. Distinção de ouro: WAF protege a aplicação web/servidor web (L7); NGFW protege o tráfego da rede como um todo.

• SSL/TLS Inspection

An NGFW capability that decrypts TLS-encrypted traffic (acting as a trusted middle-man), inspects the content for threats, and re-encrypts it before forwarding.

⚠ **Exam Trap:** 'Firewall decrypts and examines HTTPS/TLS traffic' → NGFW. Firewalls stateless/stateful só veem cabeçalhos e não conseguem inspecionar conteúdo cifrado.

• SQL Injection (SQLi)

An injection attack that submits malicious SQL statements through unsanitized web application input in order to read or manipulate the backend database.

⚠ **Exam Trap:** SQLi é o exemplo clássico de ataque web na prova: o dispositivo que bloqueia SQLi no tráfego HTTP é o WAF (mitigações complementares: validação de entrada e queries parametrizadas).

✓ Authentic Practice Questions (10 Real Exam Scenarios)

Scenario-based exam questions. Complete explanations and distractor analysis are provided in the answer key below.

QUESTION 1 · EXAM SCENARIO

A network team uses router ACLs that permit inbound TCP 443 to a public web server and deny all other traffic. During a review, an analyst finds that crafted packets with the ACK flag set can reach the server even though no TCP handshake was completed. The router evaluates each packet independently and has no session table. Which firewall type should be implemented to track TCP sessions and automatically permit return traffic?

- A) Stateless packet-filtering firewall
- B) Stateful firewall
- C) Web application firewall
- D) Unified Threat Management appliance

QUESTION 2 · EXAM SCENARIO

An e-commerce company has an NGFW allowing HTTPS to its web servers. Penetration testers successfully submit malicious SQL statements and script payloads through normal-looking shopping cart forms, and the NGFW does not block them because it treats the traffic as allowed HTTPS. Which dedicated firewall type is best suited to inspect HTTP request content and block SQLi and XSS?

- A) Stateless packet filter
- B) Stateful firewall
- C) Web application firewall
- D) SSL/TLS inspection gateway

QUESTION 3 · EXAM SCENARIO

A small company has separate devices for firewall, IPS, antivirus scanning, spam filtering, and web content filtering at its branch office. The IT budget cannot support renewing multiple appliances, and the administrator wants a single device that provides these layered protections. Which type of firewall solution best matches this requirement?

- A) Stateless packet filter
- B) Stateful firewall
- C) Next-generation firewall
- D) Unified Threat Management appliance

QUESTION 4 · EXAM SCENARIO

A security architect must enforce policies based on Active Directory user groups, identify SaaS applications even when they use HTTPS, consume real-time threat intelligence feeds, and decrypt outbound TLS traffic for inspection. Which firewall type is designed to meet all these requirements?

- A) Packet-filtering firewall
- B) Stateful firewall
- C) Next-generation firewall
- D) Web application firewall

QUESTION 5 · EXAM SCENARIO

Users report intermittent access failures after an administrator applies an inbound ACL on a router that permits only TCP 80 to a web server. The administrator discovers that return traffic from the server to clients is also being evaluated by a separate outbound ACL and is dropped unless an additional permit rule is added. Which limitation of the current firewall approach does this demonstrate?

- A) It cannot perform stateful inspection of established connections
- B) It cannot decrypt SSL/TLS traffic
- C) It cannot inspect HTTP request bodies
- D) It cannot authenticate users against Active Directory

QUESTION 6 · EXAM SCENARIO

A company's NGFW is configured to block malicious downloads, but most employee web traffic is now HTTPS. The firewall sees only encrypted flows and cannot apply application or threat signatures to the payload. Which capability should the security team enable on the NGFW to inspect the contents of encrypted sessions?

- A) Stateless ACL evaluation
- B) SSL/TLS inspection
- C) Web application firewall policy
- D) Virtual private network concentrator

QUESTION 7 · EXAM SCENARIO

A public web application is behind a stateful firewall that allows inbound HTTPS. Attackers are attempting cross-site request forgery and malicious script injection through legitimate HTTP parameters. The security team needs a control that understands HTTP methods, headers, cookies, and form parameters and can block these attacks before they reach the application. Which firewall type is most appropriate?

- A) Stateless packet filter
- B) Stateful firewall
- C) Web application firewall
- D) Unified Threat Management appliance

QUESTION 8 · EXAM SCENARIO

A network administrator needs to permit remote employees to reach an internal application over TCP 3389. The current firewall rule allows TCP 3389 from the internet to the application server. A security review flags that the firewall also allows unsolicited packets that appear to be part of an existing session because it never verifies sequence numbers or connection state. Which firewall type is currently deployed?

- A) Stateless packet-filtering firewall
- B) Stateful firewall
- C) Next-generation firewall
- D) Web application firewall

QUESTION 9 · EXAM SCENARIO

A mid-sized enterprise is comparing firewall platforms. The security team wants application-aware policies, user identity integration, and threat intelligence, but it also requires built-in antivirus, anti-spam, and content filtering in the same appliance to simplify branch deployments. Which solution category best describes this combined feature set?

- A)** Stateless packet filter
- B)** Stateful firewall
- C)** Next-generation firewall
- D)** Unified Threat Management appliance

QUESTION 10 · EXAM SCENARIO

A company wants to prevent employees from using unauthorized cloud storage applications. The current firewall only checks IP addresses and ports, so many applications are allowed over TCP 443. The security team needs to identify the application by its traffic patterns and apply policy based on the user's department. Which firewall technology should be selected?

- A)** Stateless packet filter
- B)** Stateful firewall
- C)** Next-generation firewall
- D)** Web application firewall

ANSWER KEY & COMPREHENSIVE DISTRACTOR EXPLANATIONS

Question 1: Option B — Stateful firewall

A stateful firewall maintains a session table and tracks the state of TCP connections. It can determine whether a packet belongs to an established or related session and automatically allow return traffic, unlike a stateless ACL that evaluates each packet in isolation.

Question 2: Option C — Web application firewall

A web application firewall operates at the application layer for HTTP and HTTPS traffic. It parses requests and responses, understands web parameters, and can block attacks such as SQL injection and cross-site scripting. SSL/TLS inspection decrypts traffic but does not by itself apply web application attack logic.

Question 3: Option D — Unified Threat Management appliance

Unified Threat Management is an all-in-one security appliance that commonly combines firewall, IPS, antivirus, anti-spam, and content filtering. It is designed to simplify deployment and management for organizations that need multiple protections in a single device.

Question 4: Option C — Next-generation firewall

A next-generation firewall integrates application awareness, user identity, threat intelligence, and often SSL/TLS inspection. A traditional stateful firewall mainly tracks connections, while a web application firewall focuses on protecting HTTP/S applications rather than providing broad identity and application control.

Question 5: Option A — It cannot perform stateful inspection of established connections

A stateless ACL does not maintain a connection state table, so return traffic must be explicitly permitted by another rule. A stateful firewall would recognize the traffic as part of an established session and allow it according to policy without requiring separate return rules.

Question 6: Option B — SSL/TLS inspection

SSL/TLS inspection allows the firewall to decrypt, inspect, and re-encrypt encrypted traffic. This lets application and threat signatures examine payloads inside HTTPS sessions. Stateless ACLs and VPN concentrators do not inspect encrypted payloads, and a WAF is typically focused on inbound web application protection.

Question 7: Option C — Web application firewall

A web application firewall is specifically designed to inspect HTTP and HTTPS application-layer traffic, including methods, headers, cookies, and parameters. It can block attacks such as cross-site request forgery, cross-site scripting, and SQL injection. Stateful firewalls mainly track connections and do not understand web request content.

Question 8: Option A — Stateless packet-filtering firewall

A stateless packet-filtering firewall makes decisions based only on individual packet header information, such as source and destination IP addresses, ports, and protocol. It does not maintain a session table or verify sequence numbers, so it can allow packets that merely appear to match a session. Stateful firewalls track connection state.

Question 9: Option D — Unified Threat Management appliance

Unified Threat Management typically combines next-generation firewall capabilities with additional security services such as antivirus, anti-spam, and content filtering in a single appliance. This all-in-one approach is often chosen for simpler branch deployments, while an NGFW alone may not include every UTM service.

Question 10: Option C — Next-generation firewall

A next-generation firewall can identify applications by their traffic characteristics, even when they use common ports such as TCP 443, and can enforce policies based on user identity or group membership. A stateful firewall mainly tracks connections, while a WAF protects inbound web applications rather than controlling employee SaaS usage.